

CVEFixes experiments: Full Files as Input

Checkpoint 8

Lívia Cavalcanti

July 2026

Evaluation Metrics

Hit@1

Success rate at rank 1

$$\frac{1}{|Q|} \sum_q \mathbb{1}[\text{rank}_q = 1]$$

Fraction of queries where the correct match is ranked **first**.

Hit@5

Success rate in top 5

$$\frac{1}{|Q|} \sum_q \mathbb{1}[\text{rank}_q \leq 5]$$

Fraction of queries where the correct match appears in **top 5**.

MRR

Mean Reciprocal Rank

$$\frac{1}{|Q|} \sum_q \frac{1}{\text{rank}_q}$$

Average inverse rank across queries — rewards **higher** placements.

CWE Recall

Type coverage

$$\frac{|\text{CWE}_{\text{retrieved}}|}{|\text{CWE}_{\text{index}}|}$$

Fraction of distinct CWE types correctly retrieved **at least once**.

AutoPatch Dataset Results (n=225)

Embedder	H@1	H@5	MRR	CWE R.
<i>Structure-Only</i>				
Combined	0.8904	0.9589	0.9162	0.4978
GIN	0.7260	0.8767	0.7879	0.4427
WL	0.6986	0.7945	0.7363	0.4386
<i>CodeBERT pretrained</i>				
CodeBERT (baseline)	0.1533	0.2200	0.1826	0.2933
CodeBERT (seq)	0.7534	0.8630	0.7927	0.4121
CodeBERT (pat)	0.7123	0.8356	0.7677	0.4147

Source: `experiments/output/checkpoint5/20260505_141347_experiment_f59ab1/results.json`

RQ1: validated — structural *graph* representations are *effective* for vulnerability pattern retrieval in a synthetic dataset.

Motivation: Function vs. File Input

Goal: compare CVEfixes retrieval when each CPG is built from the **function** field vs. the full **file** field.

Function input

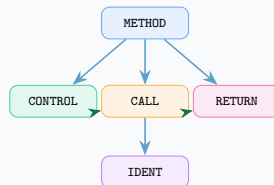
malformed CPG



1 node · label UNKNOWN · 0 edges

File input

well-formed CPG



typed nodes · solid AST / dashed CFG

Why: inspecting the function-field graphs revealed they were frequently **not well-formed** — Joern collapsed the whole body into a **single node labeled UNKNOWN**, erasing the AST / CFG structure the embedders depend on. Rebuilding each CPG from the **full file** restores proper node typing and control/data-flow edges, motivating the comparison that follows.

CVEfixes Dataset

Question: Does the approach generalize to real-world vulnerabilities?

Real-World Dataset

CVEFixes [bhandari2021cvefixes] datasets is large dataset with real-world CVEs collected from the U.S. National Vulnerability Database, patches, and code changes.

Metric	Value
CVEs	11,873
Fix commits	12,107
File changes	51,342
Method changes	277,948
Repositories	4,249

Sampling criteria

Structurally distinguishable CWEs (e.g. UAF vs. OOB) to test pattern matching, not just code similarity
Balanced superclass(CWE) up to 20 entries and subclasses (CVE) to ensure retrieval feasibility

Parameter	Value
Total pairs	136
Index set	109
Query set	27
Unique CVEs (index)	60
Unique CVEs (query)	25
CWE classes	7

Balanced Dataset + Function Graph Input: Retrieval Results

Same-CWE Retrieval (n=109 index, 27 query)

Embedder	Hit@1	Hit@5	MRR	CWE Recall
GIN	0.259	0.778	0.315	0.202
Combined	0.111	0.778	0.223	0.189
CodeBERT (baseline)	0.080	0.1518	0.098	0.141
CodeBERT (seq)	0.556	0.926	0.555	0.264
CodeBERT (pat)	0.519	0.889	0.549	0.276

Source: cvefixes_experiments/output/pipeline_verification/results.json

Per-CWE Breakdown (CodeBERT Pattern, CWE Hit@k)

CWE	N	Hit@1	Hit@5	Hit@10
Integer Overflow (190)	4	75%	100%	100%
Input Validation (20)	4	75%	75%	100%
Resource Consump. (400)	3	67%	100%	100%
Use After Free (416)	4	50%	100%	100%
NULL Ptr Deref (476)	5	40%	80%	80%
Race Condition (362)	3	33%	100%	100%
OOB Write (787)	4	25%	75%	75%
Overall	27	51.9%	88.9%	92.6%

Source: same file (CodeBERT Pattern cell)

Highlights areas for improvement in embedding design or slicing strategy.

Function vs. File: Same-Split Comparison

Function-level vs File-level Input (identical paired sample & split: n=122 index, 37 query; seed 42; G_{vuln})

Embedder	Input	Hit@1	Hit@5	Hit@10	MRR	CWE R.
GIN	function	0.108	0.243	0.270	0.152	0.205
GIN	file	0.081	0.189	0.216	0.122	0.145
Combined	function	0.054	0.432	0.486	0.190	0.192
Combined	file	0.622	0.649	0.730	0.642	0.255
CodeBERT (seq)	function	0.351	0.595	0.730	0.451	0.249
CodeBERT (seq)	file	0.811	0.865	0.919	0.845	0.281
CodeBERT (pat)	function	0.351	0.649	0.784	0.463	0.264
CodeBERT (pat)	file	0.757	0.811	0.865	0.785	0.289

On an **identical sample and split** (both levels share the same 122 index / 37 query instances), file-level input strongly improves the semantic and fusion embedders — Combined Hit@1 **+0.57**, CodeBERT (seq) Hit@1 **+0.46** / MRR **+0.39**, CodeBERT (pat) Hit@1 **+0.41**. The exception is **GIN** (pure topology, **-0.03** Hit@1): the wider file context adds structure the semantic embedders exploit but that slightly dilutes GIN's topology-only signal.

Index-Distribution Study: Proportional vs. Balanced

Shared query set, index CWE distribution varied (n=78 query, 140-entry index; G_{vuln} ; **bold** = better)

Embedder	Index	Hit@1	Hit@5	Hit@10	MRR	CWE R.
CodeBERT (seq)	proportional	0.359	0.462	0.551	0.410	0.265
	balanced	0.282	0.462	0.603	0.377	0.226
CodeBERT (pat)	proportional	0.269	0.487	0.590	0.366	0.268
	balanced	0.269	0.500	0.603	0.364	0.244
Combined	proportional	0.192	0.333	0.410	0.257	0.223
	balanced	0.103	0.256	0.346	0.172	0.214
GIN	proportional	0.064	0.321	0.397	0.166	0.195
	balanced	0.051	0.231	0.321	0.116	0.186

Same 78 queries, two equal-size (140) indices differing *only* in CWE mix: **proportional** (natural) vs. **balanced** (uniform). Proportional wins on almost every metric — matching the index mix to the query distribution concentrates capacity where the queries fall. The drop from balancing is largest for the structural embedders (**Combined** Hit@1 -0.09 , MRR -0.08 ; **GIN** Hit@5 -0.09); **CodeBERT** is more robust, with balanced only edging ahead on deep recall (Hit@10, $+0.05$ seq).

Similarity-Threshold Gating: How It Works

Selective retrieval: gate the top-1 hit on its similarity score

For each threshold t on the **CWE** axis (top-1 retrieved CWE = query CWE): accept the top-1 hit iff similarity $s \geq t$ (*answered* / “has class”), else *abstain* (“no class”).

Confusion matrix at threshold t

	correct	wrong
answered ($s \geq t$)	TP	FP
abstained ($s < t$)	FN	TN

Derived metrics (per threshold)

$$\text{coverage} = \frac{TP + FP}{N} \quad \text{recall} = \frac{TP}{TP + FN}$$
$$\text{sel. acc.} = \frac{TP}{TP + FP} \quad F_1 = \frac{2PR}{P + R}$$

N = # queries (known CWE) · P = precision (= sel. acc.) · R = recall

- **FN** — abstained, but top-1 was right (a lost hit).
- **TN** — abstained, and top-1 was wrong (a genuine reject — good).

Sweep t over $[0, 1]$; the reported operating point is the F_1 -**optimal** threshold t^* . Raising t trades **coverage** (fewer answered) for **precision** (cleaner answers) — the results that follow.

Similarity-Threshold Gating: Exact-CVE Axis

Selective retrieval on the CVE instance (top-1 CVE match, G_{vuln} ; F_1 -optimal threshold t^*)

Embedder	CVE@1	t^*	Cov.	Acc	Answered	Abstained
	base				ok / wr	FN / TN
CodeBERT (seq)	0.355	0.70	0.67	0.431	22 / 29	5 / 20
CodeBERT (pat)	0.303	0.60	0.84	0.359	23 / 41	0 / 12
Combined	0.205	0.60	0.69	0.278	15 / 39	1 / 23
GIN	0.145	0.90	0.97	0.149	11 / 63	0 / 2

Gate: accept top-1 only if similarity $\geq t^*$ (*answered* = "has instance"), else abstain. Acc = exact-CVE precision among answered; ok/wr = answered & correct/wrong; FN/TN = abstained but top-1 was correct / correctly rejected. Same query set & run as the CWE-axis slide.

Source: 20260702_113946_cvefixes_retrieval_grid_file_level_e1a036 · threshold_analysis.json

Matching the *exact CVE* is far harder than the CWE class, so base precision roughly halves (**CodeBERT seq** 0.671 $\rightarrow$ 0.355). Gating still helps — seq's threshold of 0.70 lifts exact-CVE precision **35.5% $\rightarrow$ 43.1%** at **67%** coverage — but the ceiling stays low and false positives remain high (**29** answered-but-wrong even after gating). The embedder ordering is preserved (seq > pat > combined > gin); **GIN** stays **uncalibrated** ($t^*=0.90$ still answers $\sim$ everything at **14.9%** precision).

Similarity-Threshold Gating: Trading Coverage for Precision

Selective retrieval on the CWE class (top-1 CWE match, G_{vuln} ; F_1 -optimal threshold t^*)

Embedder	CWE@1	t^*	Cov.	Acc	Answered	Abstained
	base				ok / wr	FN / TN
CodeBERT (seq)	0.671	0.70	0.67	0.824	42 / 9	9 / 16
CodeBERT (pat)	0.645	0.60	0.84	0.719	46 / 18	3 / 9
Combined	0.538	0.60	0.69	0.630	34 / 20	8 / 16
GIN	0.408	—	1.00	0.408	31 / 45	0 / 0

Gate: accept top-1 only if similarity $\geq t^*$ (*answered* = "has class"), else abstain ("no class"). Acc = CWE precision among answered; ok/wr = answered & correct/wrong; FN/TN = abstained but top-1 was correct / correctly rejected.

Source: 20260702_113946_cvefixes_retrieval_grid_file_level_e1a036 · threshold_analysis.json

Gating on similarity trades **coverage** for **precision**: for **CodeBERT (seq)**, a threshold of 0.70 lifts top-1 CWE precision from **67.1%** to **82.4%** while still answering **67%** of queries — **16** of its **25** abstentions are genuine rejects (would-be-wrong), only **9** are lost hits. **GIN** is the exception: its similarities are uncalibrated (compressed 0.82–0.98 range), so its best threshold is 0 — **gating cannot tell right from wrong**.

Questions?

Lívia Cavalcanti |  graph-rag/